7. Assessment Limitations and Conclusion

7.1 Assessment Overview

The IT Security Risk Assessment was conducted on November 3, 2026, using Greenbone Community Edition against an intentionally vulnerable Metasploitable virtual machine hosted within a Proxmox VE laboratory environment.

The assessment combined technical vulnerability identification with simulated business risk analysis, internal control mapping, and risk treatment planning.

The project demonstrated a structured process for converting technical security findings into information that could support management review and risk-based decision-making.

Because the assessment was conducted in a laboratory rather than an operational business environment, its conclusions are limited to the documented technical findings and the assumptions used in the simulated risk assessment.

7.2 Technical Assessment Limitations

7.2.1 Single-System Scope

The vulnerability assessment was limited to one target:

Metasploitable VM 120 — `10.10.50.10`

No additional production servers, employee endpoints, cloud resources, enterprise applications, or organizational networks were assessed.

Consequently, the results cannot be generalized to a broader IT environment.

7.2.2 Automated Vulnerability Detection

Greenbone Community Edition served as the primary technical assessment tool.

Automated vulnerability scanning can identify known vulnerabilities, exposed services, insecure configurations, and other security weaknesses. However, scanner findings require interpretation because detection methods and supporting evidence vary.

The assessment distinguished between findings supported by demonstrated behavior and findings based on service exposure, software versions, or vulnerability detection logic.

For example:

- The Ingreslock finding demonstrated remote command execution with Linux root privileges.
- The DistCC finding demonstrated remote command execution under the daemon account.
- The Apache Tomcat AJP finding demonstrated unauthorized retrieval of an application configuration file.
- The TWiki finding was supported by version detection rather than independently demonstrated exploitation.

These distinctions were maintained to avoid overstating the evidence.

7.2.3 Limited Detailed Finding Review

The completed Greenbone scan reported 66 findings:

Technical Severity	Findings
Critical	13
High	8
Medium	39
Low	6
Total	**66**

Detailed analysis focused on the 13 Critical results.

Two findings associated with the same vsftpd backdoor vulnerability were consolidated, producing 12 distinct risks in the Risk Register.

The remaining eight High, 39 Medium, and six Low findings were included in the scan summary but were not individually assessed.

Therefore, the 12-risk register does not represent a comprehensive analysis of every vulnerability identified by Greenbone.

7.2.4 No Comprehensive Penetration Test

The project was a vulnerability assessment, not a full penetration test.

Although Greenbone performed active security checks and demonstrated certain weaknesses, the assessment did not attempt to exploit every finding, establish attack chains, evaluate lateral movement, or determine the full consequences of a hypothetical system compromise.

The results should not be interpreted as a comprehensive demonstration of exploitability.

7.3 Laboratory Environment Limitations

The Metasploitable system was intentionally designed to contain vulnerable services and insecure configurations.

Its security weaknesses were expected characteristics of the training environment rather than unexpected deficiencies in a production system.

The laboratory incorporated safeguards intended to separate the vulnerable target from the home network, including:

- A Proxmox laboratory bridge without a physical uplink.
- No configured default gateway on the Metasploitable target.
- Disabled IP forwarding on the dual-network Greenbone scanner.
- Firewall forwarding restrictions on the scanner.

These safeguards reduced the potential for unintended network connectivity.

However, complete isolation was not independently established through exhaustive verification of every possible physical, virtual, or forwarding path.

Accordingly, the report describes the environment as an **intended isolated laboratory**, rather than claiming that every possible network path was conclusively tested.

7.4 Business Risk Assessment Limitations

The business risk analysis used a hypothetical production scenario in which the vulnerable server was assumed to support business applications and be accessible from an internal corporate network.

This scenario provided a basis for demonstrating likelihood and impact scoring.

The assessment produced:

Inherent Risk Rating	Number of Risks
Critical	9
High	3
Medium	0
Low	0
Total	**12**

These ratings are provisional and illustrative.

They were not based on an actual organization's:

- Business impact analysis.
- Asset classification.
- Threat intelligence specific to its environment.
- Documented risk appetite.
- Existing compensating controls.
- Operational dependencies.
- Historical security incidents.

As a result, the ratings should not be presented as approved enterprise risk determinations.

The assessment also did not calculate residual risk because no remediation or control effectiveness evaluation was completed.

7.5 Internal Control Assessment Limitations

The project mapped the 12 registered risks to relevant concepts from the COSO Internal Control Framework and NIST SP 800-53.

These mappings identified safeguards that could help address the documented security weaknesses.

However, the assessment did not examine an actual organization's policies, procedures, control ownership, management oversight, or evidence of control operation.

No formal testing was performed to determine whether organizational controls were:

1. Appropriately designed.
2. Implemented as intended.
3. Operating effectively over a defined period.

The control mappings therefore represent **potential control considerations**, not confirmed organizational deficiencies.

This report does not express an IT audit opinion or provide assurance regarding any production organization's internal control environment.

7.6 Remediation and Residual Risk Limitations

The Risk Treatment Plan documented proposed corrective actions for all 12 registered risks.

Nine risks were assigned P1 priority, and three were assigned P2 priority.

All 12 risks were assigned a proposed mitigation strategy.

At the conclusion of the assessment:

Treatment Status	Result
Registered Risks	12
Risks Remaining Open	12
Remediation Activities Started	0
Verified Remediations	0
Residual Risk Assessments Completed	0
Formal Management Risk Acceptances	0

The target was intentionally maintained in a vulnerable state for educational purposes.

No corrective actions were implemented, no follow-up remediation testing was performed, and no residual risk ratings were established.

Therefore, the Risk Treatment Plan represents **recommended future actions**, not completed security improvements.

7.7 Overall Assessment Conclusions

The assessment supports five principal conclusions.

Conclusion 1 — Significant Technical Weaknesses Were Identified

Greenbone reported 66 findings affecting the intentionally vulnerable Metasploitable target.

The detailed review of the 13 Critical results identified 12 distinct security risks involving remote execution, authentication weaknesses, unsupported software, insecure services, and application exposure.

Conclusion 2 — Technical Evidence Requires Careful Interpretation

The assessment demonstrated that scanner results vary in evidentiary strength.

Some findings provided direct evidence of command execution, successful authentication, or unauthorized file retrieval.

Other findings were based on detected software versions, exposed services, or scanner detection logic.

Accurate risk reporting requires preserving these distinctions.

Conclusion 3 — Technical Severity and Business Risk Are Different

CVSS scores describe technical vulnerability severity.

Business risk additionally depends on the importance of the affected system, potential consequences, threat exposure, and relevant security controls.

The simulated risk assessment demonstrated how likelihood and impact scoring can supplement technical severity when prioritizing management attention.

Conclusion 4 — Vulnerability Findings Can Inform Internal Control Discussions

The identified weaknesses were mapped to relevant COSO and NIST SP 800-53 control concepts.

These mappings demonstrated how vulnerability assessment evidence can inform discussions about authentication, privileged access, secure configuration, patch management, and network protection.

However, identifying relevant controls is not equivalent to testing their effectiveness.

Conclusion 5 — Risk Management Requires Follow-Through

The project documented risk treatment recommendations, priorities, simulated owners, and proposed validation methods.

In a production environment, effective risk management would also require accountable ownership, approved remediation plans, implementation evidence, validation testing, and residual risk decisions.

Those activities were outside the scope of this laboratory assessment.

7.8 Recommended Next Steps

If the methodology were applied to an actual organization, the following steps would be appropriate.

Recommended Step	Purpose
Confirm Business Context	Identify affected business processes, data, and system criticality
Expand Assessment Coverage	Evaluate additional in-scope assets and relevant vulnerabilities
Validate Significant Findings	Confirm the technical basis and practical exposure of prioritized weaknesses
Review Existing Controls	Determine which safeguards are implemented and how they operate
Confirm Risk Ratings	Adjust likelihood and impact using actual organizational context
Assign Accountable Owners	Establish responsibility for treatment decisions and corrective actions
Approve Remediation Plans	Set priorities, target dates, and escalation requirements
Implement Corrective Actions	Address the underlying security weaknesses

Recommended Step	Purpose
Validate Remediation	Review evidence and perform targeted retesting
Assess Residual Risk	Determine remaining exposure and obtain appropriate management decisions

For this laboratory project, a useful future extension would be to create a separate remediation exercise, implement selected corrective actions, and compare before-and-after vulnerability scan results.

That extension would provide an opportunity to demonstrate remediation validation without changing the evidence or conclusions of the original November 3, 2026, assessment.

7.9 Final Assessment Statement

The November 3, 2026, assessment identified substantial technical security weaknesses within an intentionally vulnerable Metasploitable virtual machine.

Through Greenbone vulnerability scanning, technical evidence review, finding consolidation, simulated likelihood and impact scoring, internal control mapping, and risk treatment planning, the project demonstrated an end-to-end IT security risk assessment workflow.

The resulting documentation includes a vulnerability scan report, a 12-entry Risk Register, a Risk Scoring Methodology, a Risk Treatment Plan, an Executive Dashboard, and this formal assessment report.

Under the hypothetical production scenario, the nine Critical and three High inherent risks would warrant prioritized management attention and corrective action.

Final Conclusion: The assessment successfully demonstrated a structured, evidence-based approach to identifying technical vulnerabilities and translating them into business-oriented IT security risks. Its findings and recommendations apply to an intentionally vulnerable laboratory system and a simulated production scenario. No conclusions are expressed regarding an actual organization's security posture, internal control effectiveness, remediation status, or residual risk.

End of IT Security Risk Assessment Report